

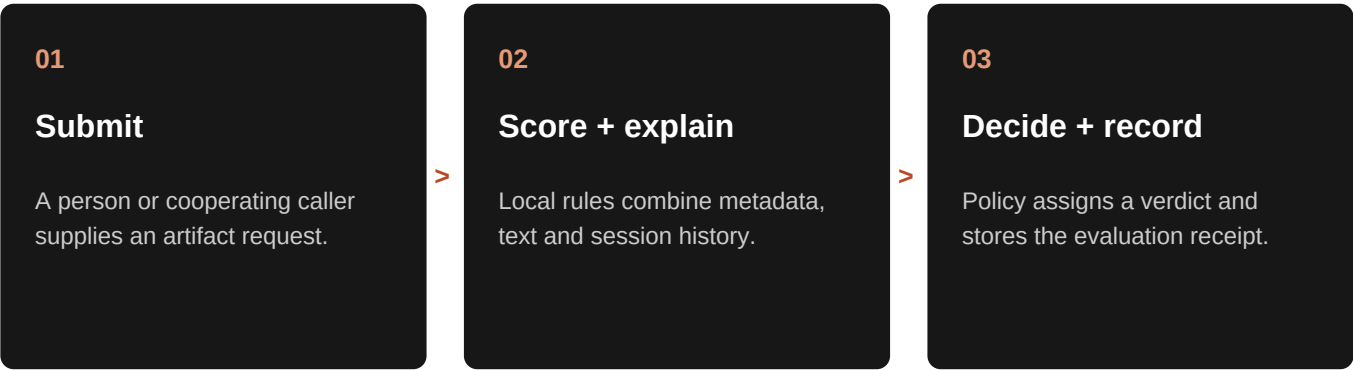
PROJECT GUIDE / IMPLEMENTED MVP

A checkpoint for AI-agent artifacts.

MOSAIC scores the external resources an AI coding agent wants to use. It returns a risk score, explains the contributing signals, and recommends allow, review, or deny.



THE WORKING PATH



What the MVP demonstrates

One request format and review workflow across four artifact types. A deterministic score with visible evidence. A concrete example of earlier session activity changing a later decision.

THE CURRENT BOUNDARY

The gateway supplies decisions. An integrating caller must obey them. This version does not automatically intercept agent commands, installations, MCP calls or network traffic.

02 / CAPABILITIES

What works today

The console, API, scoring rules, human review and local persistence are connected. Buttons create and update real stored records.

ARTIFACT TYPE	WHAT MOSAIC CAN INSPECT
Package	Reported existence, age, downloads, signature and permissions; static text; name similarity against a small built-in package catalog.
Skill / rules file	The same supplied metadata plus static instruction-override patterns and related session history.
MCP server	Supplied server metadata and manifest-like text. MCP means Model Context Protocol: a way for an agent to call external tools.
Remote URL	Local URL parsing, HTTPS use and literal local/private host checks, alongside supplied evidence. No URL is fetched.

Working controls

YOU CAN	RESULT
Inspect and filter	Search artifacts or sessions; filter type and verdict; paginate; open the evidence and receipt drawer.
Follow a session	Choose a session, inspect its trace, then view its full request list. The trace shows the latest five events.
Resolve a hold	Allow or deny a pending review with a required note. The original score and receipt remain unchanged.
Edit policy	Save review/deny thresholds, toggle correlation, discard edits and preview a score without recording an evaluation.
Replay and export	Run four synthetic workflows through the real API. Download a JSON audit export for offline checking.

State survives restarts in a local JSON store. A new store starts with 10 synthetic observations. These examples are separate from real connected-agent traffic.

03 / SCORING

From evidence to a decision

The score is a rule-based triage result from 0 to 100. It is not a probability of compromise or a guarantee that an artifact is safe.

score = min(100, sum of signal points)

Current signal weights are all 1. No model API or API key is required.



DEFAULT THRESHOLDS / CHANGES APPLY TO FUTURE EVALUATIONS

EXAMPLE SIGNAL	POINTS / CONDITION
Existence	48 if explicitly reported missing; 8 if existence is unspecified.
Package lookalike	26 for a close match to a name in the small package catalog.
Metadata	10 unsigned; 8 younger than 7 days; 7 with fewer than 50 reported downloads.
Permissions and text	Elevated permissions: 8 each, capped at 24. Text indicators add 16-24 points; instruction override adds 22 for skills/MCP.
URL indicators	12 non-HTTPS; 20 local/private literal host; 20 for a URL that cannot be parsed.
Session context	6 per earlier non-allowed request of another type, capped at 18; another 12 for matching normalized names.

WORKED EXAMPLE / LINKED TRUST SIGNALS

25 + 6 + 12 = 43 / Review

A skill's reported age, adoption and unsigned status total 25 points. An earlier denied URL in the same session adds 6; the shared name adds 12. Without correlation, the skill scores 25 and is allowed under the default policy.

Context uses the most recent 20 earlier evaluations in the same session and their original policy decisions. Human overrides do not rewrite that scoring history. Full rule details: docs/SCORING.md.

04 / WALKTHROUGH

A short demonstration

Use the default policy (review 35, deny 70, correlation on) for the expected results below. Every replay creates a fresh session.

01

Start with a clean request

Open Replay workflow and choose Known publisher install. The signed package has no configured risk indicators, scores 0 and receives Allow.

02

Show why history matters

Replay Linked trust signals. The URL scores 100 and is denied; the later skill scores 43 and needs review. Open the skill in Session trace to see its individual signals.

03

Use the dropdowns and filters

Choose a different session, then return to the linked session. Select View session to show both records. In Requests, filter by artifact type or decision and search by name or session.

04

Make a human decision

Open Review queue, inspect a pending request and enter a reviewer note. Choose Allow request or Deny request. The queue updates and the recorded override appears in the details.

05

Change the decision policy

Open Policy, edit a threshold or toggle correlation, and save. The preview slider illustrates the boundaries. Replay again to evaluate with the new policy; existing records retain their original scores.

06

Evaluate your own input and export

Choose New evaluation, select one of the four types, and supply a name and session. Add optional metadata, text or permissions. Inspect the result, then download the audit trail.

USEFUL CONTROLS

Press N for a new evaluation and / to search. Escape closes a dialog. Replay supports arrow keys. If a submission loses connection, Reconnect keeps the draft available.

05 / LIMITS

What is not present yet

The current release is a single-user local prototype. These boundaries explain what a successful demo establishes and what it does not.

MISSING CAPABILITY	PRACTICAL IMPLICATION
Automatic interception	No agent wrapper, package-command hook, skill-read hook, MCP proxy or HTTP enforcement proxy is installed. A caller can ignore a verdict.
Independent evidence	No live npm/PyPI registry checks, DNS/WHOIS reputation, signature verification or trusted skills/MCP registry. Metadata comes from the submitter.
Broad analysis	No semantic prompt-injection classifier, sandbox execution or full package scanner. The catalog and text rules are deliberately small; false positives and false negatives are possible.
Hallucination database	No cross-model consensus database or dedicated hallucinated-name detector. Name similarity is only an illustrative package check.
Signed audit receipts	Evaluations form a SHA-256 hash chain. They are not signed or externally anchored; someone who rewrites the whole store can recompute the chain.
Multi-user operations	No authentication, roles, tenants or reviewer identity. No multi-process database coordination. The server defaults to loopback access.
Validated research results	No 200-500-case labeled corpus, baseline comparison, detection-rate measurement, false-positive rate or end-to-end latency benchmark.

AUDIT VERIFICATION SCOPE

The export verifier checks original evaluation contents and their links. Review and policy events are recorded separately and are not authenticated by this chain. Exported requests may contain the text supplied by the caller.

06 / ROADMAP

From MVP to the final project

The original brief describes a larger runtime defense and research evaluation. The items below are planned work, not capabilities already delivered or guaranteed research outcomes.

01 Connect and enforce

Add supported coding-agent adapters, package and skill hooks, an MCP proxy and controlled HTTP egress.

Completion evidence: requests are intercepted before use; deny stops the action; review pauses and resumes it correctly.

02 Verify the evidence

Add registry existence checks, provenance verification, trusted catalogs and URL reputation sources with explicit failure handling.

Completion evidence: decisions use independently collected evidence, including clear handling of unknown or unavailable results.

03 Strengthen scoring and audit

Expand detectors and cross-artifact signals, add the proposed hallucination-name dataset, and design signed receipts and durable storage.

Completion evidence: documented signal tests, calibrated thresholds and authenticated audit records. Learned weights remain an optional experiment.

04 Build the research evaluation

Curate the brief's 200-500 labeled cases and benign controls. Compare with Pipelock and mcp-firewall under a reproducible method.

Completion evidence: detection and false-positive rates, coverage and latency results, plus correlation-on/off ablation and stated limitations.

05 Package a usable release

Document supported agents and deployment, add access controls where needed, publish reproducibility materials and prepare the research report.

Completion evidence: another team can install, demonstrate and reproduce the reported results from the release instructions.

Research claims such as novelty or superiority need a current literature review and measured evidence. The MVP does not establish those claims.

07 / REFERENCE

Run, integrate and verify

The current implementation uses React + TypeScript for the console and an Express API with a local JSON store. Use Node.js 22 or newer.

```
npm ci
npm run build
npm start
```

Open **http://127.0.0.1:4318**. For development, **npm run dev** opens the console on 4317 with the API on 4318. User data lives in **data/** and is excluded from Git.

API ROUTE	PURPOSE
GET /api/state	Evaluations, active policy and replay choices.
POST /api/evaluate	Submit type, name, sessionId and optional source, content and metadata; receive score, signals, decision and receipt.
POST /api/reviews/:id	Resolve a pending hold with an allow/deny decision and a note.
PATCH /api/policy	Save reviewThreshold, denyThreshold and correlationEnabled.
POST /api/scenarios/:id/run	Record a synthetic workflow in a new session.
GET /api/export	Download evaluations, policy and audit events as JSON.

VERIFIED FOR THIS REVISION

21 Playwright browser tests and 18 engine/API/audit tests pass locally. Coverage includes dropdowns, all artifact forms, reviews, policy persistence, filtering, keyboard use, mobile layout, downloads and recovery from connection failures. Browser tests use isolated temporary stores.

Run checks: npm run check; npm run test:browser.
Verify an export: npm run verify:audit -- path/to/mosaic-audit.json.
Windows browser tests use installed Edge; other platforms require Playwright Chromium. See README.md for setup.

Implementation: FireFlamingo/MOSAIC, revision cd09532. Details: README.md, docs/MVP.md, docs/SCORING.md, server/engine.ts and tests/browser/.
Planning source: supplied agent-firewall-brief.pdf, v1.0, especially sections 5 and 8. Planned research claims are not independently verified by this guide.